EWB Courses

Assessment 01: AI-Powered Cybersecurity

Student Name: Tamanna Prakash

Batch / Group: ----------

Course: AI-Powered Cybersecurity

Assessment: Security Foundations

Total Marks: 100

Task A: Secure a Student Account

A1. Five security risks

Risk	Asset at risk	CIA impact
Manavi uses the same short password for her email and learning portal.	Email and learning portal accounts	Confidentiality: Someone who discovers the password may access both accounts.
Manavi approves unexpected sign-in prompts.	Student account and personal information	Confidentiality: An unauthorised person may gain access to her account.
Manavi delays device updates.	Laptop and stored information	Confidentiality, Integrity and Availability: Known security weaknesses may be exploited to steal, change or disrupt data.
Manavi keeps only one copy of her projects on her laptop.	Academic projects and assignments	Availability: If the laptop is damaged, lost or infected, she may lose important work.
Manavi lets her friend use her laptop while she remains signed in.	Email, learning portal and personal files	Confidentiality and Integrity: Her friend may view, copy or modify private information.

A2. Practical security controls and priorities

1. **Use strong, unique passwords:** Manavi should create a different, long password for each account and use a password manager if possible. This reduces the risk of one leaked password affecting multiple accounts. However, the password manager itself must also be protected.
2. **Never approve unexpected MFA prompts:** Manavi should deny unfamiliar sign-in requests and report repeated prompts to the IT team. This helps prevent unauthorised access, although MFA alone cannot stop every attack.
3. **Install device updates promptly:** She should enable automatic updates and restart the laptop when required. Updates fix known security weaknesses, although they cannot protect against every new threat.
4. **Maintain backups:** Manavi should keep another copy of her project files in a secure cloud location or external drive. Backups help recover lost work, but they must also be protected and updated regularly.
5. **Lock the laptop and sign out:** She should use a screen lock, create a separate user account for her friend and sign out of sensitive services. This reduces unauthorised access, although it cannot prevent every form of physical access.

My first three priorities

My first priority would be to stop approving unexpected sign-in prompts because an attacker may already be trying to access the account. Second, I would change the reused password because one compromised password could expose multiple accounts. Third, I would install pending security updates to reduce the risk of known vulnerabilities. These actions address immediate account threats before improving the device's longer-term security.

A3. Authentication versus authorisation

Authentication means verifying who a person is. For example, Manavi enters her username and password and completes an MFA check to prove that she is the account owner.

Authorisation determines what an authenticated person is allowed to do. For example, Manavi may be allowed to view and submit her own assignments, while a teacher may have permission to view and grade students' submissions.

Therefore, authentication verifies identity, whereas authorisation controls access and permissions.

Task B: Analyse a Suspicious Message

B1. Five warning signs in the message

Warning sign (message phrase)	Why it is suspicious
FINAL WARNING - scholarship expires in 20 minutes	Creates urgency and pressures the student to act without checking the information.
Reply-To: help@personal-awards.example	The reply address is different from the sender's address and uses a different domain. This needs verification.
enter your college password and OTP	A genuine scholarship process should not ask students to share their password and OTP through a suspicious link.
Do not contact the college office because their system is unavailable	Discourages independent verification and tries to prevent the student from checking the message.
Reply with a photo of your identity card	Requests sensitive personal information that could be misused for identity fraud.

B2. Safe verification process

Manavi should not click the link or reply to the message. She should independently visit her college's official website or learning portal by typing its known address into her browser. She can also contact the scholarship office using a phone number or email address obtained from an official college source.

She should ask the college whether the scholarship has actually been approved and whether any verification is required.

HTTPS only means that the connection between the browser and website is encrypted. It does not prove that the website is genuine or trustworthy. Similarly, a familiar display name can be copied by anyone, so it is not enough to prove the sender's identity.

B3. Response plan if a student has entered a password and OTP

1. **Secure the account immediately:** The student should use the official college portal or contact the IT team through an independently verified channel to change the compromised password. They should also change it anywhere else it was reused.
2. **Report the incident:** Inform the college's IT or cybersecurity team immediately. Explain that the password and OTP were entered on a suspicious website.
3. **Protect active sessions:** Ask the IT team to revoke active sessions, review MFA settings and check for unfamiliar devices or account changes.
4. **Check for suspicious activity:** Review recent sign-ins, emails, account recovery details and any unauthorised changes.
5. **Protect personal information:** If an identity card photo was also shared, inform the relevant college office and follow its guidance on protecting identity information.

The student should never send their password or OTP to anyone, including someone claiming to be from IT support.

B4. One important fact that cannot be established

We cannot confirm from the message alone whether the sender is genuinely connected to the college or whether the scholarship has actually been approved.

Additional evidence, such as confirmation from the official scholarship office, verified email records and information from the college's official portal, would help establish whether the message is genuine.

Task C: Triage a Sign-in Alert

C1. Four-point timeline

Time	Observed event	Interpretation
09:00–09:01	student07 successfully logged in from the usual IP address 192.0.2.10 and approved MFA.	This appears to be a normal sign-in from the usual classroom network.
10:14–10:16	A login attempt came from 198.51.100.23. The password was accepted, followed by failed password attempts.	Someone may have obtained the correct password, but the later failures suggest repeated login attempts.
10:17–10:18	MFA was successful and then denied. Manavi says she approved a prompt at around 10:18 because she wanted to stop repeated requests.	Her approval may have allowed an unauthorised sign-in. However, the exact relationship between the approval and the successful MFA event needs further investigation.
10:20	A session was created from 198.51.100.23.	This indicates that a session was established. It requires investigation because Manavi says she did not sign in after 09:05.

C2. Likely explanation and alternative explanation

Likely explanation:

An unauthorised person may have obtained student07's password and attempted to sign in from a different network. The repeated MFA requests may have confused or pressured Manavi into approving one of them. This could have allowed the person to create a session at 10:20.

Alternative explanation:

The login could have been caused by a legitimate service, a VPN or another authorised device using a different network address. The available information is not enough to identify who used the IP address.

Two additional checks:

1. Review device details, browser information and session records to check whether the sign-in came from a recognised device.
2. Check the MFA logs and authentication records to establish which prompt was approved and whether it was connected to the session created at 10:20.

C3. Three prioritised response actions for the authorised IT team

1. **Protect the account:** Temporarily block or secure the account, revoke active sessions and reset the password through the official process. Review MFA settings and require secure re-enrolment if necessary.
2. **Preserve evidence:** Save the original sign-in logs, MFA records, timestamps, IP addresses and session information before making changes. This helps investigators understand what happened.
3. **Investigate and monitor:** Review device information, account activity and recent changes. Check for suspicious emails, altered recovery details or unauthorised access. Continue monitoring the account for further unusual activity.

C4. Incident summary

The sign-in logs show that student07 successfully logged in from the usual classroom IP address at 09:00. At 10:14, another login attempt came from a different IP address, followed by password and MFA events. Manavi stated that she approved an unexpected MFA prompt around 10:18. A session was created at 10:20. This suggests a possible account compromise, but the identity of the user and the reason for the different IP address are not confirmed. The IT team should secure the account, preserve evidence and investigate further.

Task D: Review an AI Security Answer

D1. Five unsafe or unsupported claims and corrections

AI-generated claim/action	Why it is incorrect and the correct advice
The email is safe because it uses HTTPS.	HTTPS encrypts the connection but does not prove that a website is genuine. Manavi should verify the website through the college's official portal.
The sign-in logs prove that the person using 198.51.100.23 stole the password.	An IP address does not identify a person or prove how a password was obtained. The IT team should investigate device details and authentication records.
MFA prevents every account compromise.	MFA improves account security but cannot prevent every attack. For example, users may accidentally approve unexpected sign-in prompts.
Delete the suspicious logs.	Deleting logs destroys important evidence. The authorised IT team should preserve them for investigation.
Send the student's password to support so they can test it.	Passwords are confidential and should never be shared. Support staff should use secure account recovery and verification procedures instead.

D2. A better prompt for an AI tool

"Analyse only the fictional cybersecurity evidence provided in this assessment. Identify possible security risks and explain the evidence supporting each finding. Clearly separate observed facts from assumptions and possible explanations. Do not identify a person based only on an IP address. Do not request passwords, OTPs or other sensitive information. Explain the uncertainty and recommend safe, practical actions. Do not invent information that is not included in the evidence."

D3. Corrected security advice

The scholarship email should be treated as suspicious because it creates urgency, requests a college password and OTP, uses a different reply-to address and asks for an identity card photograph. The student should not click the link or share personal information. Instead, they should independently contact the official college scholarship office to verify the message. The

sign-in records also show unusual activity from a different IP address and an unexpected MFA approval. However, an IP address alone cannot identify an attacker or prove how the password was obtained. The IT team should secure the account, revoke suspicious sessions, preserve the logs and investigate the activity. Passwords and OTPs must never be shared with anyone.

D4. AI-use declaration and evidence/reference notes

AI-use declaration:

I used ChatGPT to help organise my answers, understand cybersecurity concepts and improve the wording of this assessment. I reviewed the suggestions and used the fictional scenarios provided in the assessment. I am responsible for checking and understanding the final answers.

Reference 1:

CISA – Secure Our World
https://www.cisa.gov/secure-our-world

This resource provides guidance on using strong passwords, enabling MFA, recognising phishing and updating software.

Reference 2:

NIST – Artificial Intelligence Risk Management Framework: Generative AI Profile (AI 600-1)
https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf

This resource explains risks such as inaccurate AI-generated information and the importance of human review and verification.